

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia, Member, and Cons. Fabio
Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016 (hereinafter, "Regulation");

HAVING REGARD TO the Code regarding the protection of personal data, containing provisions for the adaptation of the national legal system to Regulation (EU) 2016/679 (Legislative Decree No. 196 of June 30, 2003, as amended by Legislative Decree No. 101 of August 10, 2018, hereinafter "Code");

HAVING REGARD TO the inspection assessments conducted by the Special Privacy and Technological Fraud Unit of the Guardia di Finanza on October 8, 9, and 10, 2019, at the registered office of NH Italia S.p.A. (in Milan); on October 16, 2019, at the NH Collection Roma Centro Hotel (located in Rome), and lastly, on October 17, 2019, at the offices of NH Italia S.p.A. (located in Rome);

HAVING EXAMINED the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the Regulation of the Guarantor No. 1/2000;

REPORTING Prof. Pasquale Stanzione;

PREMISE

1. The inspection activity concerning the Company.

As part of a control activity initiated ex officio by the Authority, on October 8, 9, 10, 16, and 17, 2019, an on-site assessment was carried out (at the above-mentioned locations) concerning "NH Italia S.p.A." (hereinafter "Company" or "NH Italia").

The aforementioned Company, which has its registered office in Milan and is part of the hotel group "NH Hotel Group" based in Madrid (Spain), manages several hotel facilities located throughout the national territory.

Specifically, the Guarantor's control activity concerned the processing of personal data related to customers collected by NH Italia, in the context of the hotel activity carried out at the aforementioned facilities.

In this regard, during the assessment, based on the statements made by the Company, it emerged that:

NH Italia is a company that is part of the NH Hotel Group and has a license to use the NH, NH Collection, and NH Now brands "established on 05/21/2004," which "carries out activities of 'Hotels' and ancillary activities (e.g., Restaurant, bar)" through various hotel facilities (about 50) located throughout the national territory;

the ownership of the processing of personal data of customers "who make reservations through the website www.nh-hotels.it or through the reservation centers (Central Reservation Office-CRO)" lies with NH Hotel Group S.A., the parent company of NH Hotel Group (see minutes of October 8, 2019, p. 4);

the Company specified that some of the aforementioned facilities are directly managed by NH Italia, while others "have a management contract" (see minutes of October 8, 2019, p. 3);

if a "management contract has been signed," regarding the processing "data related to invoicing, the ownership lies with the company that signed the management contract owning the hotel facility" (see minutes of October 8, 2019, p. 4 and minutes of October 9, 2019, p. 2);

NH Italia acts as an autonomous data controller concerning the personal data of customers collected, due to their stay, at the hotel facilities directly managed by it, all for the purpose of pursuing the objectives related to the relevant administrative-accounting obligations (see minutes of October 8, 2019, p. 4 and minutes of October 9, 2019, p. 2);

in this capacity, during the check-in of guests, NH Italia collects “identifying/personal, accounting, and tax data” and contact details of the interested parties, namely: name, surname, date and place of birth, province of birth, nationality, email address, as well as the details of an identification document and payment instruments (see minutes of October 9, 2019, p. 4 and attachment 4 containing screenshots of a check-in following a reservation for a stay at a hotel facility managed by NH Italia);

the collection of the above-mentioned data occurs at the time of the completion and signing, by the customers at check-in, of the form called “Registration form”; a form where, among other things, the so-called “Basic Information on Data Protection” is provided, in this circumstance, by the Company to the customers (see minutes of October 9, 2019, pp. 2 and 4 and attachment 4 containing the aforementioned form);

moreover, “it may happen that a customer [...] freely communicates, in the notes field, data related to any allergies and/or food intolerances”;

in this regard, the Company stated that “such information is retained only for the duration of the customer’s stay” (see minutes of October 9, 2019, p. 4);

finally, “in almost all [...] hotel facilities a [...] video surveillance system is installed”; concerning this, the Company clarified that regarding the underlying data processing, the ownership “is exclusively with NH Italia S.p.A.” (see minutes of October 9, 2019, p. 2);

regarding the processing of personal data carried out by NH Italia due to the installation of the aforementioned video surveillance systems at the hotel facilities indicated by the Company and the designation of the data processing manager, pursuant to Article 28 of the Regulation, to be carried out with respect to the maintenance companies of the systems, “specific appointments for such processing have not been made” (see minutes of October 17, 2019, page 2 and attachment 28 containing the list of facilities managed by NH Italia, where the systems have been installed). Subsequently, to resolve the reservations expressed during the inspection activity, NH Italia, with communications dated October 31, 2019, and November 5, 2019, provided further elements, including documentary evidence, regarding the aforementioned processing; all this as a supplement to what emerged following the investigations carried out. In particular, with the aforementioned communications, the data regarding the total number of registered customers (i.e., 29 million) in the Company’s Customer Relationship Management (CRM) database was acquired, as well as confirmation of the communication to the Guarantor on October 21, 2019, of the contact details of the Data Protection Officer (identified in the figure of the Data Protection Officer for NH Hotel Group, previously designated by the Group). It is worth highlighting that, as a result of the complex investigation initiated and in light of the examination of the elements resulting from the records, some critical profiles were found that deserve a more in-depth analysis by the Authority. Therefore, with notes dated January 29, 2021, and September 30, 2021, two further requests for information were made to NH Italia pursuant to Article 157 of the Code, particularly concerning the aspects relating to:

- a) the provision for acquiring specific consent for the collection of data regarding any allergies and/or food intolerances provided by customers and the role played by NH Italia in relation to such processing;
- b) the regulation of contractual relationships with the companies that process, on behalf of NH Italia, the personal data acquired through the video surveillance systems;
- c) the methods by which information is provided to guests regarding their stay at the facilities managed by NH Italia, taking into account what is reported in the so-called Registration Form, regarding the possibility for customers to “obtain further details about the [...] Data Protection Policy” at check-in.

First of all, regarding the profile mentioned in point a), the company, with its response note dated February 26, 2021, to the first request for information dated January 29, 2021, reiterated what had previously been stated during the inspection investigations regarding the methods of acquiring customers’ personal data concerning allergies and/or food intolerances (see above paragraph 1),

clarifying, at the same time, that such information is not generally collected during the check-in phase, as it is not necessary for the stay. In fact, as specified by NH Italia in this communication, such information can be provided subsequently by the customer, who “voluntarily” and “residually” makes it known to the hotel staff (for example, if they wish to use the dining service). In this circumstance, the hotel staff verbally asks the interested party if they can record the relevant indication in the “notes field” of the booking program, called “TMS system,” of the Company, also informing them “that the data will be deleted at the end of the stay” (see note of February 26, 2021, page 2 and attachment 1 containing the registration form signed by a customer at check-in and a copy of a screenshot of the TMS system where the preference expressed by the hotel guest to receive a “gluten-free breakfast” is evident in the “notes field”).

Regarding the other profiles subject to further investigation, specifically the one mentioned in point b), it is noted that the Company, with the same note dated February 26, 2021, provided an updated list of the hotel facilities where video surveillance systems have been installed (this is attachment 3 to the note dated February 26, 2021, which thus replaces the one previously transmitted during the investigations referred to in attachment 28 of the minutes of October 17, 2019), along with the agreements—concluded after the aforementioned inspection activity—containing the designations of the data processing manager, with respect to the companies responsible for the installation and maintenance of the video surveillance systems. In this regard, it was also specified that “there are no supply agreements but the service [of design, installation, and maintenance] is carried out “on request” through ad hoc orders from the individual hotel based on specific needs” and that “some hotels have been closed due to the health emergency and for others, maintenance activities are carried out internally by NH Italia staff” (see note of February 26, 2021, page 2).

Furthermore, attached to the same note dated February 26, 2021, as requested by the Authority in the communication dated January 29, 2021, NH Italia transmitted the list of 51 hotel facilities located throughout the national territory that have a license to use the NH, NH Collection, and NH Now brands and that are managed by the Company, from which it is evident, among other things, the number of NH Italia employees operating at each facility (a total of 1335).

Subsequently, with a note received on October 28, 2021, NH Italia, in addition to the documentation and information already provided to the Authority and in response to further clarifications requested by the latter on September 30, 2021, regarding the aspects referred to in points a) and b), specified the following:

“NH Italia is the data controller in relation to all data necessary for the provision of hotel services” provided at the facilities managed by it in the national territory (see note of October 28, 2021, p. 1); regarding the aforementioned processing of customer data carried out by NH Italia, customers receive the relevant information, which, as reiterated by the Company, is delivered to all customers in the registration form (so-called Registration Form), at the moment they provide their data to the hotel reception. It contains basic information on the protection of personal data and simultaneously indicates, in the section “Additional Information,” the possibility of receiving a more extensive notice contained in the detailed data protection policy prepared by the Company. This document, titled “Data Protection Notice” (see Annex 3 of the note of October 28, 2021), is provided to the customer at the reception desk or “in electronic format through the email address of the Data Protection Officer” (see note of October 28, 2021, p. 2); notwithstanding the above, regarding any additional information collected by NH Italia related to customer allergies and/or food intolerances, which, as mentioned above, are “stored in the notes field present in the TMS system of [...] the Company,” the Company reiterated that “generally it does not collect [such] information (...)” unless in cases where, “to avoid incidents,” a customer voluntarily provides the same. It was also specified that these remain exclusively available to NH Italia until the conclusion of the stay, and are therefore processed “only by NH Italia S.p.A.” (see note of October 28, 2021, p. 1); it was lastly represented that NH Italia, following the investigations conducted by the Authority, has defined “a procedure to regulate the [occasional] processing of the above data with the aim of ensuring the privacy of the data subjects”; a procedure with respect to which “NH Italia S.p.A. is configured as the data controller” and which provides as the

legal basis for the same the express consent of the data subject (see note of October 28, 2021, p. 1 and Annex 1 containing the model of information and acquisition of the related consent prepared on the matter by NH Italia).

****2. Initiation of the procedure for the adoption of corrective measures.****

On February 21, 2022, the Office notified the Company, pursuant to Article 166, paragraph 5, of the Code, of the alleged violations found, with reference to Articles 5, paragraph 1, letter a) and 9 of the Regulation; Articles 5, paragraph 1, letter a) and 13 of the Regulation; as well as Article 28 of the Regulation.

With the subsequent note of March 23, 2022, the Company sent its defensive writings, stating that: regarding the processing of data related to allergies and/or food intolerances of guests carried out by NH Italia, these “were collected only in cases where the data subjects provided them voluntarily, being fully aware that they were providing them so that they could be taken into account for the provision of services by NH ITALIA. Therefore, consent was granted by the user orally.” It follows that the related processing was residual and merely “occasional, involving a very limited number of data subjects,” given that “as a rule, this type of data is not collected.” In any case, it was emphasized that it was implemented to safeguard the health of guests given the possible implications arising from the failure to provide such information (see note of March 23, 2022, pp. 6 and 9); following the investigations initiated by this Authority, NH Italia has implemented a specific internal procedure concerning the processing of information related to the health status of guests at hotel facilities; a procedure that involved, on one hand, the drafting of a specific notice in this regard on the protection of such particular categories of data to be released to the data subjects and, on the other hand, the provision of a system for acquiring and recording, as the legal basis for this specific processing, the express consent for the processing of data related to allergies and/or food intolerances. The Company also specified that “such information will be deleted when the customer checks out, so that they will be definitively eliminated from NH ITALIA's systems,” without prejudice to the possibility for “guests who regularly stay at NH ITALIA” to provide an additional and distinct consent aimed at allowing “NH ITALIA to retain [such information] for a period of two years.” Finally, “as an improvement action by NH ITALIA, in relation to the processing [of the aforementioned] information, in order to verify the correct regularization of consents for the processing of sensitive data and the implementation of the procedure, the company (...) is proceeding to verify the correct definitive deletion of sensitive data from NH ITALIA's systems, so as to comply with the process regulated by [the same] procedure” (see note of March 23, 2022, pp. 3 and 9). In this regard, it is noted that the document containing the “Procedure for the obligation of information and obtaining consent for the collection of data related to allergies and food intolerances,” was attached by the Company to the note dated March 23, 2022; regarding the processing of data carried out to ensure the safety of individuals and places through the video surveillance systems located at the hotel facilities managed by NH Italia, it has fulfilled the obligations regarding information as per Article 13 of the Regulation also through the display of dedicated signs, while simultaneously utilizing various suppliers for the installation and maintenance thereof, following the signing, as already specified in the note dated February 26, 2021, of ad hoc contracts with such appointed parties. In this regard, the Company wishes to clarify that the aforementioned suppliers “do not have continuous access to the images collected by the installed video surveillance cameras.” Rather, “the services provided by these subjects concern the maintenance of the cameras as the physical means through which images of NH ITALIA's facilities are recorded.” Furthermore, the aforementioned contracts “refer to the data protection regulations as per Article 28 of the GDPR” and contain the instructions provided by the data controller to the processor in accordance with the provisions of the relevant legislation. “Therefore, it should be noted that the relationship with suppliers who may have access to the images is adequately regulated in accordance with the applicable data protection laws” (see note dated March 23, 2022, pp. 4-5).

3. Observations on the legislation regarding personal data protection relevant to the case and established violations.

With specific reference to the legislation on personal data protection and the violations established by

this Office within the procedure, it is first represented that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the Guarantor."

Having duly stated this, following the investigative activity and the subsequent assessments carried out by the Authority regarding this matter, it has been established, based on the elements acquired during the inspections conducted by the Special Privacy and Technological Fraud Unit of the Guardia di Finanza and the examination of the documentation and other elements subsequently transmitted to the Guarantor, that NH Italia has engaged in unlawful processing of personal data at the hotel facilities located throughout the national territory that it manages.

This is because NH Italia, as the data controller, has carried out, as further detailed below, processing operations that are primarily in violation of Article 5 of the Regulation; this provision identifies the fundamental principles applicable to any processing of personal data. By virtue of this provision, the data controller is indeed required to respect the aforementioned principles, including those according to which personal data must be "processed lawfully, fairly, and transparently in relation to the data subject" (Article 5, paragraph 1, letter a) of the Regulation).

In particular, concerning the specific processing carried out by NH Italia that is the subject of the Authority's assessment, it has been found that regarding the collection of information related to any allergies and/or food intolerances carried out due to requests made by guests during their stay at the hotels, this was done in the absence of an appropriate legal basis, and therefore in violation of Articles 5, paragraph 1, letter a) and 9 of the Regulation, as well as based on incomplete and inadequate information (on this point), thus violating Articles 5, paragraph 1, letter a) and 13 of the Regulation (see *infra* paragraph 3.1).

Furthermore, regarding the processing of data carried out in connection with the installation of video surveillance systems at the aforementioned facilities, it was noted during the inspections that NH Italia failed to previously regulate, in accordance with Article 28 of the Regulation, the related relationship established with the companies responsible for their maintenance (see *infra* paragraph 3.2).

In this regard, the following observations are made.

3.1 Unlawful processing of data related to any allergies and/or food intolerances of customers.

Following the checks carried out by this Authority, it has primarily emerged that NH Italia, during the stay of customers at the hotel facilities, acquires and records in the booking system, albeit not systematically, also the personal data of guests related to any allergies and/or food intolerances. In this regard, it is first pointed out that, pursuant to Article 4, paragraph 1, points 15 and 2 of the Regulation, "health data" are those "related to the physical or mental health of a natural person, including the provision of health care services, revealing information about their health status," while "processing" refers to "any operation or set of operations [...] such as collection, recording, organization, [...], storage [...], consultation [...], communication by transmission, dissemination, or any other form of making available."

It is also represented that regarding the

****Protection of Personal Data****

Regarding personal data that falls under the so-called "special categories," Article 9, paragraph 1, of the Regulation prohibits the processing of such information. Given that health-related data is included among the special categories of personal data, it is emphasized that there is a prohibition on carrying out any processing operation among those indicated above (Article 9, paragraph 1, of the Regulation). However, this prohibition may be waived in the presence of the lawful conditions provided for in the subsequent paragraph 2 of Article 9 of the Regulation, among which is the prior acquisition of the explicit consent of the data subject.

In this regard, it is important to highlight that consent, as a prerequisite for the legitimacy of processing, must always be expressed through a positive act by which the data subject manifests a free, specific, and unequivocal will regarding the processing of personal data concerning them (Recitals 32 and 43, Articles 4, paragraph 1, point 11, 5, 6, paragraph 1, letter a) and 7 of the Regulation; see also

Guidelines 5/2020 on consent under Regulation (EU) 2016/679, adopted by the European Data Protection Board on May 4, 2020, particularly paragraph 3 and Judgment C-61/19, of November 11, 2020). Furthermore, with specific reference to health data—considering the nature of such information, which is particularly sensitive in terms of fundamental rights and freedoms—the legislator has provided, as already pointed out above, an additional requirement for consent to be considered validly given: that it be provided in explicit form (Article 9, paragraph 2, letter a) and Recital 51 of the Regulation and paragraph 4 of the aforementioned Guidelines 5/2020).

Notwithstanding the above regarding the methods of obtaining consent by the data controller, it should also be noted that, based on the principle of transparency set forth in Article 5, paragraph 1, letter a) of the Regulation, there is an additional obligation on the part of the data controller as provided for in Article 13 of the Regulation. According to this regulatory provision, the data controller is indeed required to provide the data subject, at the time when the personal data is obtained, with all information concerning the data that relates to them, including information regarding the purposes and methods of the specific processing, as well as an indication of the legal basis for the same. All of this is in the perspective of ensuring that the processing is carried out in a correct and transparent manner, in compliance with the provisions of Articles 5, paragraph 1, letter a), 12, paragraph 1, and 13 of the Regulation (see also Recitals 39 and 58 of the Regulation), and so that the data subject, if consent represents the condition for the lawfulness of the processing, can "easily identify the consequences of the consent given and [...] this is expressed with full knowledge of the facts" (cf. C-61/19, of November 11, 2020, cited, paragraph 53).

Finally, regarding the burden of proof of the existence of a valid manifestation of will for the collection of data, this burden lies with the data controller (who could, for example, prepare a request in this regard in the form of a written declaration to be presented in a comprehensible and easily accessible manner to the data subjects; cf. point 4 of Guidelines 5/2020, cited). It is indeed the latter, by virtue of what is provided for in the Regulation, who must be able to demonstrate that the data subject has consented to the processing of the data concerning them (Article 5, paragraph 2 and 7, paragraph 1 and Recital 42 of the Regulation).

Having duly stated this, starting from the overall regulatory framework described above, the documentation in the records shows that NH Italia has carried out processing of guest data who make specific requests during their stay, due to their health conditions, in violation of the principles of lawfulness, fairness, and transparency (Article 5, paragraph 1, letter a) of the Regulation).

This is particularly relevant considering that data concerning any allergies and/or food intolerances of customers, which are subject to specific verification in this case, fall within the category of personal data related to health (cf., in this sense, also the Decision of the Guarantor of December 20, 2012, web doc no. 2337668 and the latest Decision of the Guarantor of October 20, 2022, web doc no. 9831081); a category that indeed includes "all data concerning the health status of the data subject that reveal information related to their physical health [...] past, present, or future" (Recital 35 of the Regulation).

While acknowledging that, due to the collection of information carried out during the check-in of guests by NH Italia in order to allow, within the exercise of hotel activity, their stay at its facilities, the Company provides them with the related information contained in the so-called Registration form (cf. Annex 4 of the minutes of October 9, 2019) and in the document containing the detailed Data Protection Policy (see Annex 3 of the Company's note of October 28, 2021), it should be emphasized that, regarding any further processing of special categories of personal data, the Company does not provide the data subjects, before the processing begins and in compliance with the aforementioned principle of transparency, with any clear information regarding the methods and purposes of the same, as well as regarding the corresponding legal basis (Article 13, paragraph 1, letter c) of the Regulation).

Moreover, the circumstance asserted by the Company (cf. *supra* paragraphs 1 and 2)—namely that the aforementioned data is communicated freely and orally by the data subjects—the parties involved, deve contenere specifiche disposizioni in merito all'oggetto del trattamento, alla durata, alla natura e alle finalità del trattamento, al tipo di dati personali oggetto di trattamento, alle

modalità di trattamento, nonché agli obblighi e ai diritti delle parti.

In merito alla questione in esame, la Società non ha fornito evidenza di un contratto o di un atto giuridico che regoli il rapporto con le società manutentrici degli impianti di videosorveglianza. Pertanto, non è possibile ritenere che il trattamento dei dati personali effettuato da tali società sia conforme alle disposizioni del Regolamento, in particolare agli articoli 28 e 4, par. 1, punto 8.

In conclusione, la mancanza di una regolamentazione adeguata del rapporto con le società manutentrici degli impianti di videosorveglianza comporta una violazione delle norme in materia di protezione dei dati personali, con particolare riferimento agli obblighi di responsabilità e di accountability previsti dal Regolamento.

3.3. Conclusioni.

Alla luce di quanto esposto, si evidenziano le seguenti violazioni da parte della Società:

1. Trattamento dei dati personali relativi alle allergie e/o intolleranze alimentari senza un consenso valido, esplicito e informato da parte degli interessati, in violazione degli articoli 5, par. 1, lett. a), 7, par. 1, 9 e 13 del Regolamento.
2. Mancanza di una regolamentazione adeguata del rapporto con le società manutentrici degli impianti di videosorveglianza, in violazione degli articoli 4, par. 1, punto 8 e 28 del Regolamento.

Si richiede pertanto alla Società di adottare misure correttive immediate per garantire la conformità alle disposizioni del Regolamento e di fornire un riscontro in merito alle azioni intraprese entro un termine di 30 giorni dalla ricezione della presente comunicazione.

reciprocally the two parties, allows the controller, pursuant to Article 28, paragraph 3 of the Regulation, to issue instructions to the processor, also regarding the security and retention of data, and specifies in detail what the subject matter is, the duration, the nature and purposes of the processing, the type of personal data and categories of data subjects, the obligations and rights of the controller and the processor. The processor is therefore authorized to process the data of the data subjects "only on documented instructions from the controller" (see Decision of the Guarantor of January 14, 2021, web doc no. 9542113 and more broadly on the relationship between the data controller and the data processor, see the Guidelines 07/2020 on the concepts of data controller and data processor under the GDPR, adopted by the Committee for the protection of personal data on July 7, 2021).

Having duly stated this, during the investigation conducted by the Office, it was found that NH Italia processes personal data at the facilities it manages on national territory, as the controller, assuming the corresponding responsibilities and relying, regarding the video surveillance systems located at such facilities, on the design, installation, and maintenance services offered by certain third parties, as suppliers.

Considering that in this case, the provision of the aforementioned installation and maintenance service may involve processing of personal data by the latter in the interest of the Company (even merely due to access to the images recorded by the cameras during the maintenance activity), it follows that such processing requires the preparation of "a contract or other legal act in accordance with the law of the Union or the Member States" pursuant to Article 28 of the Regulation.

The aforementioned suppliers can indeed act as processors, provided that a prior act is defined that binds the maintenance companies of the systems - as processors - to NH Italia - as the controller of the related processing - and that identifies the subject matter and duration of the processing, the nature and purpose thereof, the type of personal data and categories of data subjects, the obligations and rights of the controller and the processor; all this in compliance with the terms set forth in Article 28, paragraph 3 of the Regulation.

On this point, during the aforementioned checks, NH Italia declared that it had not adequately defined the profile related to such "video surveillance processing" operations (see minutes of October 17, 2019, p. 2); although it stated that "it [was] working [to] obtain specific authorizations" in this regard (see again minutes of October 17, 2019, p. 2).

As proof of this, with particular reference to the provision of the installation and maintenance service, only with the note of February 26, 2021, were the agreements titled "Contract for the processing of personal data" transmitted, signed by NH Italia, as the controller of the underlying processing, and by the companies responsible for the maintenance of the video surveillance systems, as processors, containing the relevant designation (see in this regard annex 4 of the cited minutes).

It is therefore established that the relationship between the Company and the aforementioned suppliers has not been appropriately regulated, from the perspective of data protection, as NH Italia at the time failed, despite being obliged, to regulate based on a contract or a legal act suitable under Article 28, paragraph 3 of the Regulation, the processing of the personal data in question carried out, on its own behalf and in its own interest, by an external party (in this case, the companies providing the design, installation, and maintenance services of the systems).

All this at least until the preparation of the "agreements related to the processing of personal data" referred to in annex 4 of the note of February 26, 2021, which, as evidenced by documentation on file, were signed by the Company after the dates on which the checks carried out by the Authority took place.

For all the reasons stated above, it follows that there has been a violation in this case, based on the elements acquired and what was confirmed by the Company itself in the terms mentioned above, of Article 28 of the Regulation.

4. Conclusions: declaration of unlawfulness of the processing. Corrective measures pursuant to Article 58, paragraph 2, Regulation.

In light of what has been overall observed, the Authority believes that the statements, documentation, and reconstructions provided by the data controller during the investigation do not allow for overcoming the observations notified by the Office with the initiation act of the procedure and are therefore unsuitable to order the archiving of the present procedure, nor do any of the cases provided for in Article 11 of the Guarantor Regulation no. 1/2019 apply.

The processing of personal data carried out by the company is indeed unlawful, in the terms outlined above, with reference to the violation of the principle of lawfulness and the absence of the prerequisites for the processing of special categories of personal data (Articles 5, paragraph 1, letter a) and 9 of the Regulation); of the right to transparency and the failure to communicate adequate information regarding the processing (Articles 5, paragraph 1, letter a) and 13 of the Regulation); as well as with respect to the violation of the obligation of the controller under Article 28 of the Regulation regarding the designation of processors.

****The violation of the aforementioned provisions entails the application of the administrative sanctions provided for by Article 83, paragraph 4, letter a) and by Article 83, paragraph 5, letters a) and b), of the Regulation. In this context, considering that specific measures have been adopted to ensure that the processing in question complies with the current regulations on the protection of personal data, as extensively reported above (see supra paragraphs 3.1 and 3.2), the prerequisites for the adoption of corrective measures pursuant to Article 58, paragraph 2, of the Regulation are not currently met.****

5. ****Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166, paragraph 7, of the Code).****

The Authority, pursuant to Article 58, paragraph 2, letter i) of the Regulation and Article 166 of the Code, has the power to impose an administrative pecuniary sanction provided for by Article 83 of the Regulation, through the adoption of an injunction order (Article 18, Law of November 24, 1981, No. 689), in relation to the processing of personal data carried out by NH Italia, which has been found to be unlawful, as stated above.

It is deemed necessary to apply paragraph 3 of Article 83 of the Regulation, which provides that "if, in relation to the same processing or related processing, a data controller [...] violates, with intent or negligence, various provisions of this regulation, the total amount of the administrative pecuniary

sanction shall not exceed the amount specified for the most serious violation," the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same Article 83, paragraph 5.

With reference to the elements listed in Article 83, paragraph 2 of the Regulation for the application of the administrative pecuniary sanction and its quantification, considering that the sanction must be "effective, proportionate, and dissuasive in each individual case" (Article 83, paragraph 1 of the Regulation), it is represented that, in the case at hand, the following circumstances have been taken into account:

- In relation to the nature, gravity, and duration of the violations, the nature of the violations has been deemed significant as they concern non-compliance with the general principles of processing, particularly the principle of lawfulness and the principle of transparency. It has also been considered that the violations ceased only after the detection of the violations following checks carried out ex officio by the Authority (Article 83, paragraph 2, letter a) of the Regulation);
- With regard to the intentional or negligent nature of the violations, the negligent conduct of the Company has been taken into account, which, although it did not comply with the regulations on data protection, claimed to have processed data related to customer allergies and/or food intolerances in the interest of the guests in response to specific requests to safeguard their health. Furthermore, it contested that the services offered by the suppliers of the video surveillance systems, which involve the processing of personal data, consist solely of the maintenance of the cameras, which did not entail access, at least systematically, to the images recorded by them (Article 83, paragraph 2, letter b) of the Regulation);
- The type of information subject to violation (Article 83, paragraph 2, letter g) of the Regulation) which can also be classified within the categories of special personal data. However, it is noted in favor of the data controller that regarding this latter type of data collected by the Company, the processing involved a limited and occasional number of customers and only for the duration of their stay at the hotel facilities without any communication to third parties (Article 83, paragraph 2, letter k) of the Regulation);
- The adoption by the data controller of measures to mitigate or eliminate the consequences of the violation (Article 83, paragraph 2, letter c) of the Regulation). In this regard, it should be positively noted that NH Italia promptly adopted, once aware of the violations, the corrective measures described in the introduction, consisting of: regarding the processing of data carried out by the maintenance companies of the video surveillance systems in the absence of a designation of the same pursuant to Article 28 of the Regulation, the signing by the data controller of agreements containing such a designation; as well as, concerning the collection of health data of guests carried out by NH Italia in the absence of an appropriate legal basis and in violation of the principle of transparency, the implementation of an ad hoc procedure aimed at obtaining, in this regard, express and informed consent from the data subjects;
- The circumstance that the Company has actively cooperated with the Authority during the proceedings (Article 83, paragraph 2, letter f) of the Regulation);
- The fact that there are no previous violations committed by the data controller or previous measures pursuant to Article 58 of the Regulation (Article 83, paragraph 2, letter e) of the Regulation).

It is also considered that the economic conditions of the offender, determined based on the Company's turnover, are relevant in this case, taking into account the aforementioned principles of effectiveness, proportionality, and dissuasiveness to which the Authority must adhere in determining the amount of the sanction (Article 83, paragraph 1, of the Regulation).
of exercise for the year 2021 (latest available).

In light of the elements mentioned above and the assessments made, it is deemed appropriate, in this specific case, to apply an administrative sanction against NH Italia S.p.A. in the amount of €200,000.00 (two hundred thousand euros).

In this context, it is also considered, taking into account the type of violations identified that pertained to the general principles of processing, namely the principles of lawfulness and transparency, as well as certain special categories of personal data concerning the health of the data subjects, that pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Garante Regulation No. 1/2019, the publication of this provision on the Garante's website should proceed.

Finally, it is believed that the conditions set forth in Article 17 of Regulation No. 1/2019 are met.

ALL OF THE ABOVE CONSIDERED, THE GARANTE

notes, pursuant to Articles 57, paragraph 1, letter a) and 83 of the Regulation and Article 144, paragraph 2 of the Code, the unlawfulness of the processing carried out by NH Italia S.p.A., based in Milan, Via G.B. Pergolesi, 2/A, VAT number 04440220962, as detailed in the reasoning, for the violation of Articles 5, paragraph 1, letter a), 9, and 13 of the Regulation, as well as Article 28 of the Regulation;

believes that the conditions set forth in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers delegated to the Garante, are met.

ORDERS

pursuant to Article 58, paragraph 2, letter i) of the Regulation, NH Italia S.p.A. to pay the sum of €200,000.00 (two hundred thousand euros) as an administrative pecuniary sanction for the violations indicated in this provision.

REQUIRES

therefore NH Italia S.p.A. to pay the aforementioned sum of €200,000.00 (two hundred thousand euros), according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to Article 27 of Law No. 689/1981. It is noted that pursuant to Article 166, paragraph 8 of the Code, the offender retains the option to settle the dispute by paying – always according to the methods indicated in the annex – an amount equal to half of the imposed sanction within the term provided for the submission of the appeal as indicated below, in Article 10, paragraph 3, of Legislative Decree No. 150 of September 1, 2011.

ORDERS

the publication of this provision on the Garante's website pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Garante Regulation No. 1/2019.

Pursuant to Article 78 of the Regulation, as well as Articles 152 of the Code and 10 of Legislative Decree No. 150/2011, an appeal against this provision may be filed with the ordinary judicial authority, with a petition submitted to the ordinary court of the place identified in the same Article 10, within thirty days from the date of communication of this provision, or sixty days if the appellant resides abroad.

Rome, June 1, 2023

THE PRESIDENT

Stanzione

THE REPORTER

Stanzione

THE SECRETARY GENERAL

Mattei